

المعالجة المقترحة	مستوى الخطورة	مكانها (الملف)	اسم المشكلة
استخدام مكتبة bcrypt للتشفير كلمات المرور قبل حفظها في قاعدة البيانات، واستخدام bcrypt.compare عند تسجيل الدخول.	حرج (Critical)	src/controllers/authController.js	تخزين كلمات المرور كنص عادي (Plain Text Passwords)
استبدال دمج النصوص في استعلامات SQL باستخدام Parameterized Queries (\$1, \$2)	حرج (Critical)	src/controllers/usersController.js	ثغرة حقن قواعد البيانات (SQL Injection)
إضافة Middleware للتحقق من دور المستخدم (authorize(['admin'])) لمنع الزبون من إضافة أو تعديل المنتجات.	مرتفع (High)	src/routes/productsRoutes.js	غياب التفويض (Missing Authorization)
التحقق من أن req.user.id يطابق req.params.id قبل السماح بعرض بيانات المستخدم.	مرتفع (High)	src/controllers/usersController.js	الوصول غير المصرح به للبيانات (IDOR)
إنشاء middleware مركزي لمعالجة الأخطاء (errorHandler) يرجع رسالة عامة للمستخدم ويخفي تفاصيل النظام.	متوسط (Medium)	src/app.js	تسريب تفاصيل الأخطاء الداخلية (Stack Trace Exposure)